GANRICH
ADVISORY

WHITEPAPER · EU MARKET ACCESS

Your customer’s obligation, your evidence: NIS2 supply-chain security for Turkish suppliers

Most EU member states have now transposed the NIS2 Directive. Its supply-chain rules reach Turkish IT, software and industrial suppliers through contracts and questionnaires.

Ahmed Furkan Gul, Founder, Ganrich Advisory

October 2026

Executive summary

1. The NIS2 Directive, Directive (EU) 2022/2555, requires medium and large organisations in 18 sectors, from energy and transport to manufacturing of electronics, machinery and vehicles, to manage cybersecurity risk, including risk in their supply chain. The transposition deadline was 17 October 2024. Most member states missed it, but by spring 2026 a large majority had adopted national laws; Germany's took effect on 6 December 2025.
2. Article 21 makes supply-chain security one of the minimum measures. EU entities must take into account the vulnerabilities of each direct supplier and the quality of their products and security practices. In practice they do this through questionnaires, contract clauses, audit rights and incident notification duties placed on suppliers.
3. For a Turkish software house, managed service provider or supplier of connected industrial equipment, NIS2 is rarely a direct legal duty. It is a sales condition. The supplier that can show one credible security evidence pack, and commit to realistic incident notification, keeps the contract; the one that answers each questionnaire from scratch spends time and still looks risky.

What has changed

Directive (EU) 2022/2555 replaced the first NIS Directive and widened its scope to 18 sectors. Annex I lists sectors of high criticality, such as energy, transport, banking, health, digital infrastructure and ICT service management. Annex II lists other critical sectors, including manufacturing of medical devices, computers and electronics, electrical equipment, machinery and motor vehicles.

Member states had to transpose the Directive by 17 October 2024. The European Commission sent letters of formal notice to 23 member states on 28 November 2024 and reasoned opinions to 19 on 7 May 2025. National laws followed through 2025 and 2026, so most EU customers now have binding obligations rather than draft ones.

Article 21 lists minimum risk-management measures, including incident handling, business continuity, secure development, access control and supply-chain security. Article 21(3) asks entities to consider the vulnerabilities specific to each direct supplier and service provider, and the overall quality of their products and cybersecurity practices. Commission Implementing Regulation (EU) 2024/2690 spells out these measures in detail for digital infrastructure and ICT service providers.

Entities must also report significant incidents to national authorities: an early warning within 24 hours and an incident notification within 72 hours. They cannot meet those deadlines if a supplier takes a week to tell them about a breach, so contracts now set notification times for suppliers too.

Management bodies must approve the measures and can be held liable. That is why procurement and legal teams in EU companies have become more demanding of suppliers.

Türkiye has its own framework: Cybersecurity Law No. 7545 was published in the Official Gazette on 19 March 2025. It does not replace what EU customers ask for under NIS2, but some evidence can serve both.

The decision behind the requirement

The supplier's decision is how to answer once and well. EU customers ask overlapping questions in different formats: policies, access control, vulnerability handling, backups, subcontractors, incident response, certifications. A supplier that builds a maintained evidence pack, mapped to the main frameworks its customers use, can answer most requests in days.

The second decision is commercial. Contract clauses on notification times, audit rights and liability vary widely. Accepting a 24-hour notification duty is reasonable only if the supplier can actually detect and escalate an incident in that time. Agreeing terms that cannot be met creates exposure; refusing them can lose the customer.

A third decision is whether to pursue certification such as ISO/IEC 27001. It does not answer every question, but many EU buyers accept it as evidence for a large part of their checklist.

Five common misreadings

"NIS2 is EU law, so it does not apply to us." It reaches non-EU suppliers through contracts. Turkish groups with EU subsidiaries in Annex I or II sectors may also be in scope directly.

"An ISO 27001 certificate ends the conversation." It helps, but customers still ask about scope, subcontractors, vulnerability handling and notification times.

"Only IT companies are affected." Suppliers of connected machinery, components with software and outsourced services to manufacturers receive the same questions.

"The questionnaire is a sales formality." The answers often become contract annexes, and inaccurate answers become liability.

"Transposition is still pending, so we can wait." Most member states have adopted their laws, and customers are applying them in current tenders and renewals.

Questions for the leadership team

1. Which of our EU customers are essential or important entities under NIS2, and in which countries?
2. Have we received security questionnaires or new contract clauses in the past year, and how did we answer?
3. Do we have a current, maintained set of security policies and evidence we could share?
4. How quickly could we detect a security incident affecting a customer and notify them?
5. Which of our own subcontractors and cloud providers could affect customer systems or data?
6. How do we handle vulnerabilities in the software or devices we supply?
7. Would ISO/IEC 27001 or another certification answer most customer questions for us?
8. Who in leadership owns cybersecurity commitments made in contracts?

What a good first step produces

A useful first step is a supplier security review: the questions your main EU customers ask, the evidence you already have, the gaps, and the contract terms you can realistically accept. It should leave leadership with one evidence pack to build and a position on notification and audit clauses.

Ganrich Advisory runs this with your technical, legal and sales teams, and works with security specialists and certification bodies where they are needed. We are not a certification body and do not provide penetration testing. We share the working method in a conversation rather than in print, because it depends on your customers.

Start a conversation

furkangul@ganrichadvisory.com · ganrichadvisory.com

About this paper. This paper reflects official sources checked on 24–25 October 2026. It is general information, not legal, customs, tax or engineering advice. Rules, thresholds and dates change; confirm them against official sources before acting. It describes no client work or results.

Sources: Directive (EU) 2022/2555 (NIS2): eur-lex.europa.eu/eli/dir/2022/2555/oj · Commission Implementing Regulation (EU) 2024/2690: eur-lex.europa.eu/eli/reg_impl/2024/2690/oj · European Commission, NIS2 Directive: digital-strategy.ec.europa.eu/en/policies/nis2-directive · Cybersecurity Law No. 7545, Official Gazette of the Republic of Türkiye, 19 March 2025

© 2026 Ganrich Advisory